

COMPLIANCE READINESS — NOT A FORMAL ATTESTATION

# GARIL AI

## SOC 2 Readiness & Control Mapping

Alignment to AICPA Trust Services Criteria (Security)

---

|                |                                                   |
|----------------|---------------------------------------------------|
| Version        | 1.0                                               |
| Date           | 3 October 2026                                    |
| Audience       | Partner universities & institutional stakeholders |
| Classification | Confidential — authorised institutional use       |

### Important notice

This document describes readiness and control alignment. It is not a SOC 2 Type I or Type II report, and it has not been issued by an independent CPA firm. Formal SOC 2 attestation requires an external audit engagement.

# 1. Purpose

Universities often ask whether a SaaS or research platform is “SOC 2 compliant.” Formal SOC 2 status can only be granted through an independent CPA attestation. This document maps GARIL AI’s implemented controls to the AICPA Trust Services Criteria (primarily Security / Common Criteria) so institutional ICT and procurement teams can assess fitness for a university pilot or deployment.

## Current status

GARIL AI has completed a defensive security audit and remediation (Sep–Oct 2026). Controls below are implemented in the product and recommended operating model. A formal SOC 2 Type II engagement can be commissioned when required by a partner institution.

# 2. Trust Services Criteria covered

- CC1 — Control environment (governance roles, policies, accountability)
- CC2 — Communication & information (legal docs, policy acceptance, admin audit)
- CC3 — Risk assessment (defensive audit, remediation roadmap)
- CC4 — Monitoring (audit logs, admin analytics, operational monitoring expectations)
- CC5 — Control activities (authZ, rate limits, default-deny APIs)
- CC6 — Logical & physical access (identity, MFA-ready password policy, scoped admin)
- CC7 — System operations (backups restricted, health checks, incident process)
- CC8 — Change management (versioned releases; CI/dependency scanning backlog)
- CC9 — Risk mitigation (vendor AI/API subprocessors, university feature gates)

# 3. Control mapping (Security TSC)

| Criterion               | Control in GARIL AI                                                       | Evidence / location                             |
|-------------------------|---------------------------------------------------------------------------|-------------------------------------------------|
| CC6.1 Access security   | Authenticated sessions; default-deny APIs; active-user checks             | Auth JWT; public-api allowlist; requireAuthUser |
| CC6.2 Prior to access   | Registration gated to onboarded universities; policy acceptance           | Auth register + legal/policy flows              |
| CC6.3 Role-based access | Super-admin vs university-scoped admin; portal student/supervisor roles   | Admin console + portal auth                     |
| CC6.6 Credentials       | bcrypt password hashing; hashed reset tokens; stronger password policy    | Auth & password-policy modules                  |
| CC6.7 Transmission      | TLS at reverse proxy; HSTS in production app headers; CORS allowlist      | Deploy proxy + Helmet + CORS_ORIGIN             |
| CC7.2 Monitor           | Admin audit events; governance telemetry for AI use                       | Audit + AI governance services                  |
| CC7.3/7.4 Incidents     | Incident & alert modules in governance console; IR overview document      | Admin incidents/alerts + IR PDF                 |
| CC7.5 Recovery          | Super-admin database backup tooling; institutional backup policy expected | Admin backup APIs                               |
| CC9.2 Vendors           | Documented subprocessors (LLM, email, hosting, storage)                   | Subprocessors PDF                               |

# 4. Availability, Confidentiality, Privacy (optional criteria)

Many university contracts focus on Security. Where Availability, Confidentiality, or Privacy criteria are requested:

- Availability — reverse-proxy TLS, health endpoint, VPS sizing guidance in pilot pack; SLA terms are commercial.

- Confidentiality — university-scoped admin data access; research ownership filters; private object storage.
- Privacy — policy acceptance, retention/deletion requests, privacy settings module; see Data Protection PDF.

## 5. Gaps & roadmap (transparency)

---

- Independent SOC 2 Type II audit period — not yet commissioned
- httpOnly cookie session architecture (planned continuous improvement)
- Formal dependency vulnerability scanning in CI (planned)
- Encrypted backup-at-rest policy ownership with hosting institution
- Optional malware scanning on uploads

## 6. How universities should use this

---

- Attach to security questionnaires as “SOC 2 readiness / control mapping”
- Do not represent this PDF as a completed SOC 2 attestation
- Request a formal SOC 2 engagement if the institution's procurement policy requires an AICPA report